A 9.9 CVE. THE SANDBOX WAS A TEMPLATE.

a logged-in user could run commands on the host.

here's how.

THE SETUP

GitLab AI Gateway: the service that connects a GitLab instance to AI models.

9.9

CVSS, CVE-2026-90970

only self-hosted gateways need to act



THE TEMPLATE

users can build custom flows on the Duo Agent Platform.

a crafted flow configuration escaped the prompt template sandbox.

THE PATH

```
logged-in user
```

↓

```
crafted flow config
```

↓

```
commands on the gateway host
```

no workaround listed.



THE PATTERN

in February: CVE-2026-1868, also 9.9, through a crafted flow definition.

both are template engine weaknesses.

CHECK YOURS

- which AI gateways and flow builders do you run, including ones a team stood up alone?
- is a self-hosted GitLab gateway on 19.2.4, 19.3.2, 19.4.1 or later?
- who owns each one?

WHO OWNS THE TEMPLATE?

who owns the thing that runs your templates?

full issue: link in the comments